

Chapter 4

Authentication Applications

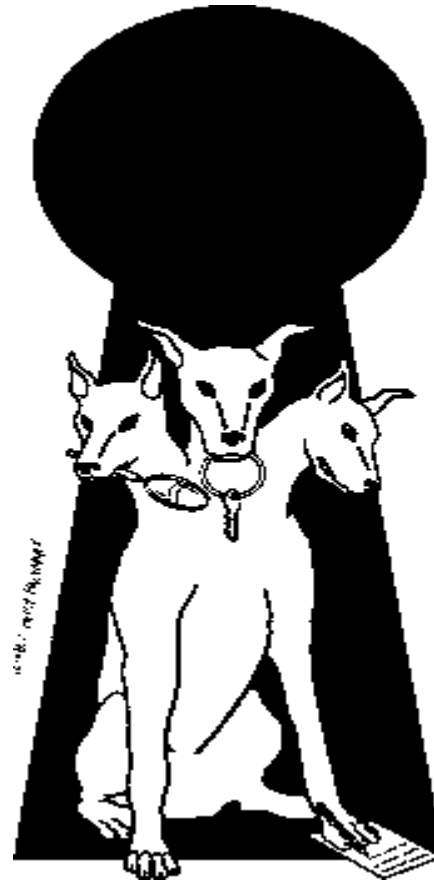
Authentication Applications

- will consider authentication functions
- developed to support application-level authentication & digital signatures
- will consider Kerberos – a private-key authentication service
- then X.509 directory authentication service

Security Concerns

- key concerns are **confidentiality** and **timeliness**
- to provide confidentiality must encrypt identification and session key info
- which requires the use of previously shared private or public keys
- need timeliness to prevent **replay attacks**
- provided by using sequence numbers or timestamps or challenge/response

KERBEROS



In Greek mythology, a many headed dog, the guardian of the entrance of Hades

KERBEROS

- Users wish to access services on servers.
- Three threats exist:
 - User pretend to be another user.
 - User alter the network address of a workstation.
 - User eavesdrop on exchanges and use a replay attack.

Kerberos

- trusted key server system from MIT
- provides centralised private-key third-party authentication in a distributed network
 - allows users access to services distributed through network
 - without needing to trust all workstations
 - rather all trust a central authentication server
- two versions in use: 4 & 5

KERBEROS

- Provides a centralized authentication server to authenticate users to servers and servers to users.
- Relies on conventional encryption, making no use of public-key encryption
- Two versions: version 4 and 5
- Version 4 makes use of DES

Kerberos Requirements

- first published report identified its requirements as:
 - security
 - reliability
 - transparency
 - scalability
- implemented using an authentication protocol based on Needham-Schroeder

Kerberos 4 Overview

- a basic third-party authentication scheme
- have an Authentication Server (AS)
 - users initially negotiate with AS to identify self
 - AS provides a non-corruptible authentication credential (ticket granting ticket TGT)
- have a Ticket Granting server (TGS)
 - users subsequently request access to other services from TGS on basis of users TGT

Kerberos Version 4

- Terms:
 - C = Client
 - AS = authentication server
 - V = server
 - ID_C = identifier of user on C
 - ID_V = identifier of V
 - P_C = password of user on C
 - AD_C = network address of C
 - K_V = secret encryption key shared by AS and V
 - TS = timestamp
 - $||$ = concatenation

A Simple Authentication Dialogue

(1) C $\rightarrow$ AS: $ID_c \parallel P_c \parallel ID_v$

(2) AS $\rightarrow$ C: Ticket

(3) C $\rightarrow$ V: $ID_c \parallel$ Ticket

$\text{Ticket} = E_{K_v}[ID_c \parallel P_c \parallel ID_v]$

Version 4 Authentication Dialogue

- Problems:
 - Lifetime associated with the ticket-granting ticket
 - If too short ☒ repeatedly asked for password
 - If too long ☒ greater opportunity to replay
- The threat is that an opponent will steal the ticket and use it before it expires

Version 4 Authentication Dialogue

Authentication Service Exchange: To obtain Ticket-Granting Ticket

- (1) C $\rightarrow$ AS: ID_C || ID_{tgs} || TS₁
- (2) AS $\rightarrow$ C: $E_{K_C} [K_{C,tgs} || ID_{tgs} || TS_2 || Lifetime_2 || Ticket_{tgs}]$

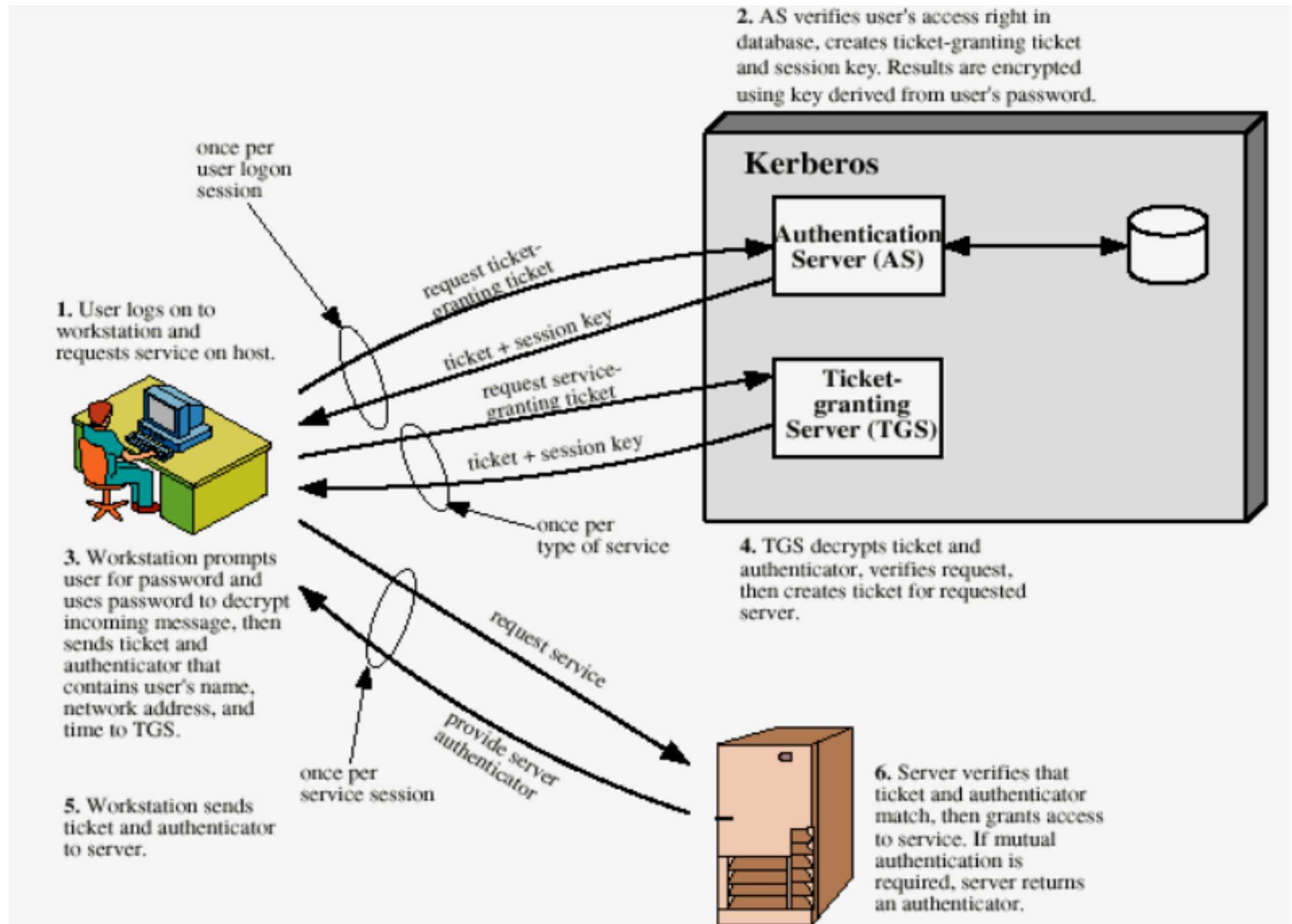
Ticket-Granting Service Exchange: To obtain Service-Granting Ticket

- (3) C $\rightarrow$ TGS: ID_V || Ticket_{tgs} || Authenticator_C
- (4) TGS $\rightarrow$ C: $E_{K_C} [K_{C,v} || ID_V || TS_4 || Ticket_v]$

Client/Server Authentication Exchange: To Obtain Service

- (5) C $\rightarrow$ V: Ticket_v || Authenticator_C
- (6) V $\rightarrow$ C: $E_{K_{C,v}} [TS_5 + 1]$

Overview of Kerberos



Kerberos Realms

- a Kerberos environment consists of:
 - a Kerberos server
 - a number of clients, all registered with server
 - application servers, sharing keys with server
- this is termed a realm
 - typically a single administrative domain
- if have multiple realms, their Kerberos servers must share keys and trust

Request for Service in Another Realm

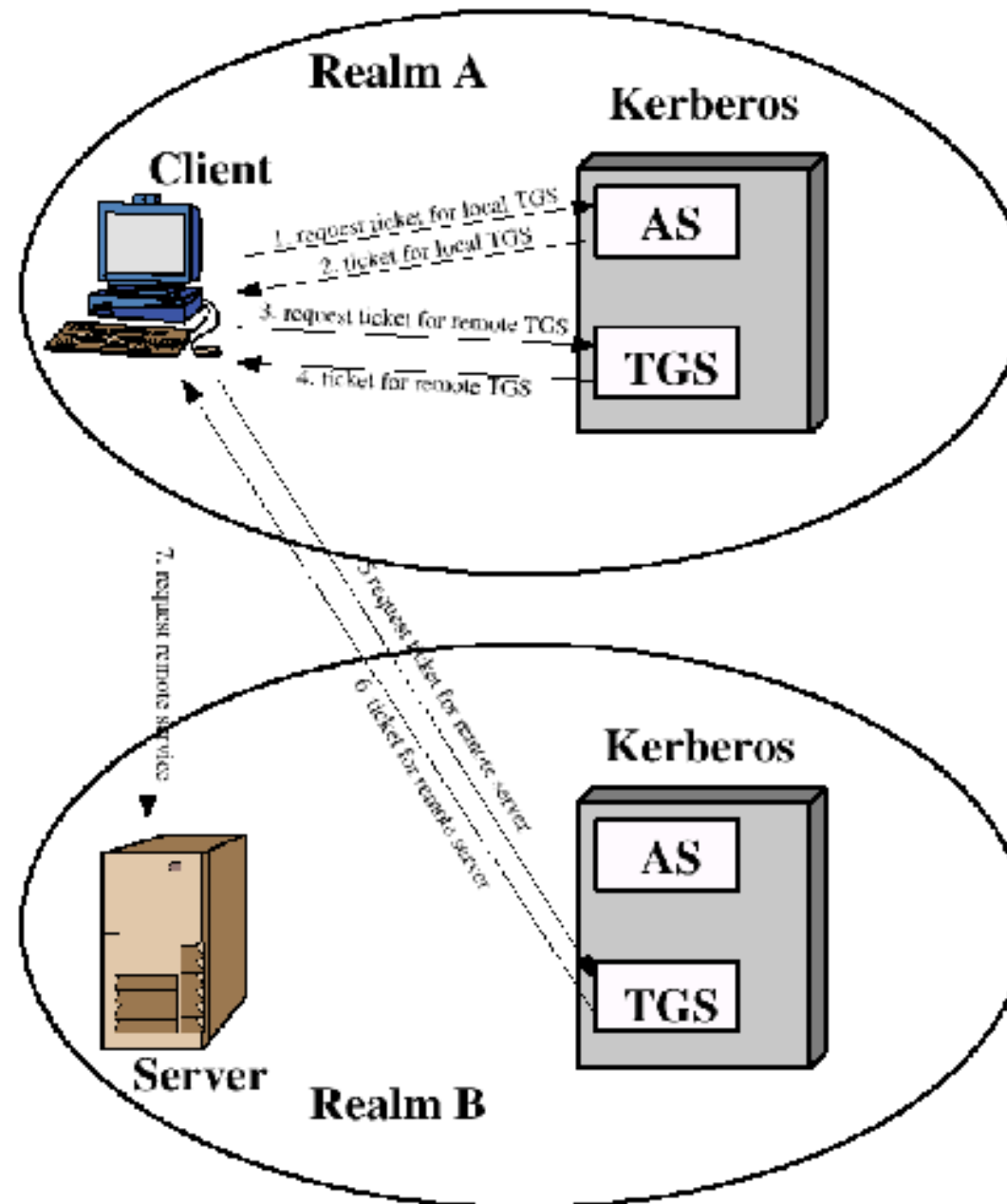


Figure 4.2 Request for Service in Another Realm

Difference Between Version 4 and 5

- Encryption system dependence (V.4 DES)
- Internet protocol dependence
- Message byte ordering
- Ticket lifetime
- Authentication forwarding
- Interrealm authentication

Kerberos Encryption Techniques

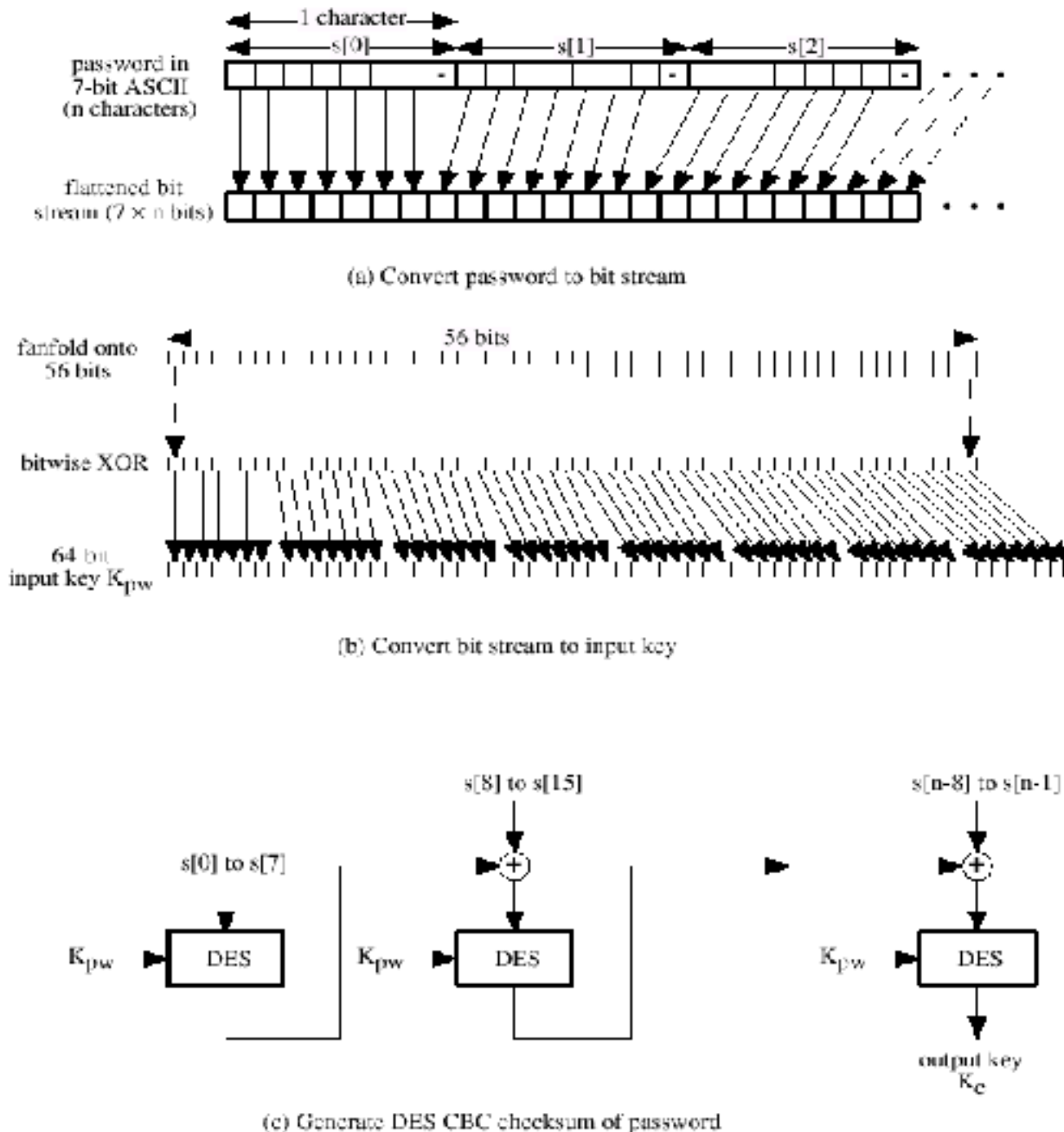


Figure 4.6 Generation of Encryption Key from Password

PCBC Mode

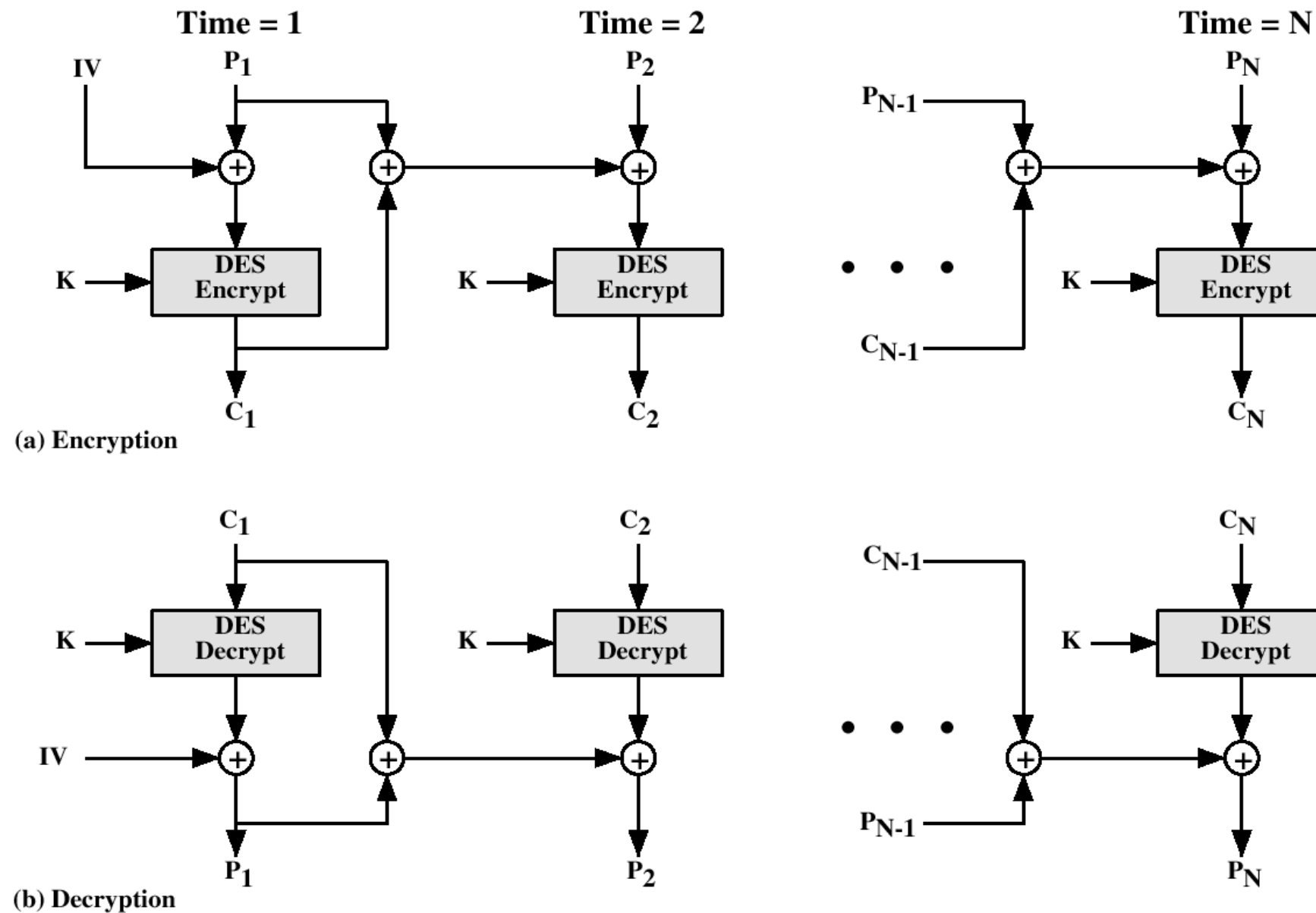


Figure 4.7 Propagating Cipher Block Chaining (PCBC) Mode

Kerberos - in practice

- **Currently have two Kerberos versions:**
- 4 : restricted to a single realm
- 5 : allows inter-realm authentication, in beta test
- Kerberos v5 is an Internet standard
- specified in RFC1510, and used by many utilities
- **To use Kerberos:**
- need to have a KDC on your network
- need to have Kerberised applications running on all participating systems
- major problem - US export restrictions
- Kerberos cannot be directly distributed outside the US in source format (& binary versions must obscure crypto routine entry points and have no encryption)
- else crypto libraries must be reimplemented locally

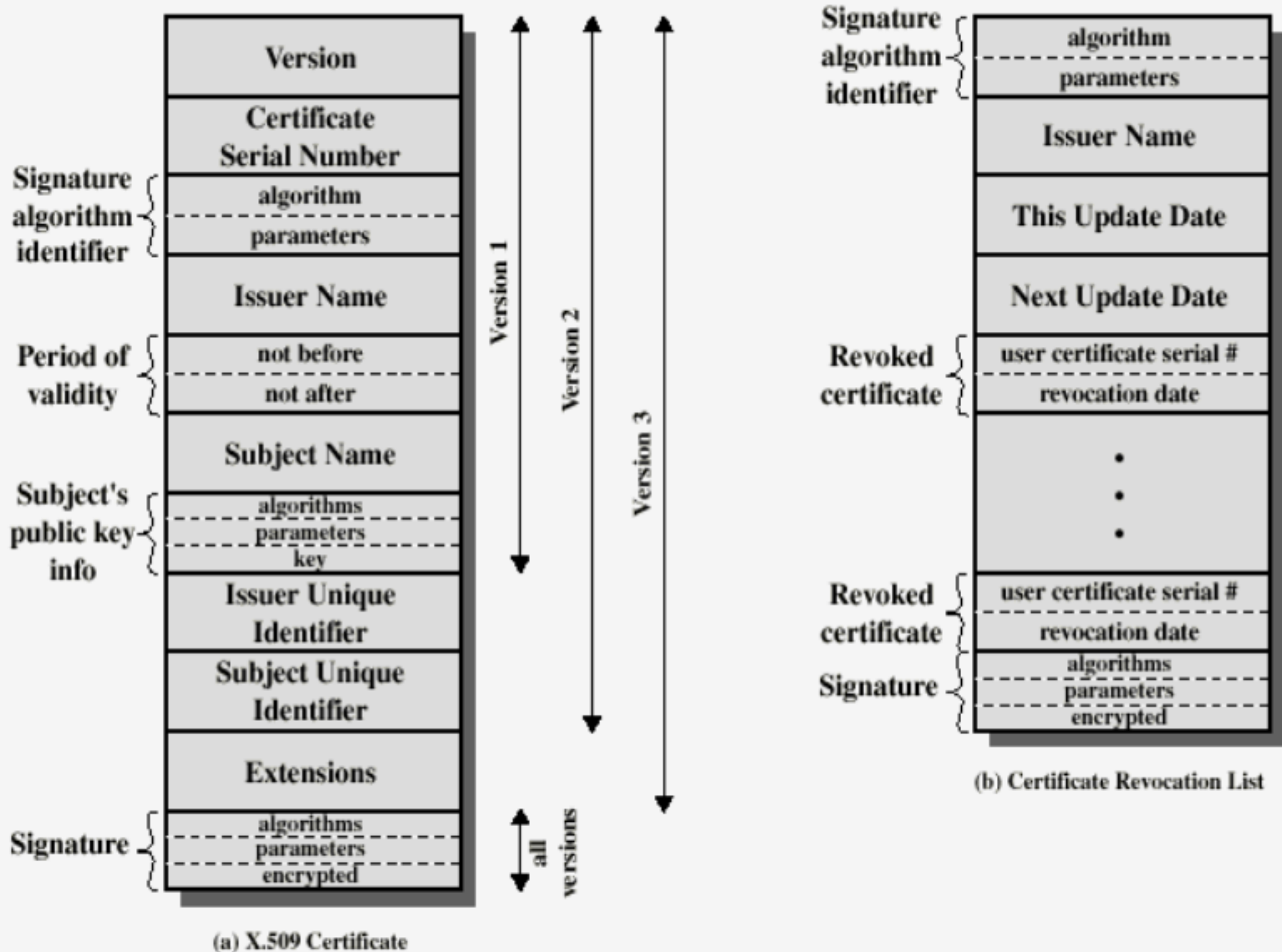
X.509 Authentication Service

- Distributed set of servers that maintains a database about users.
- Each certificate contains the public key of a user and is signed with the private key of a CA.
- Is used in S/MIME, IP Security, SSL/TLS and SET.
- RSA is recommended to use.

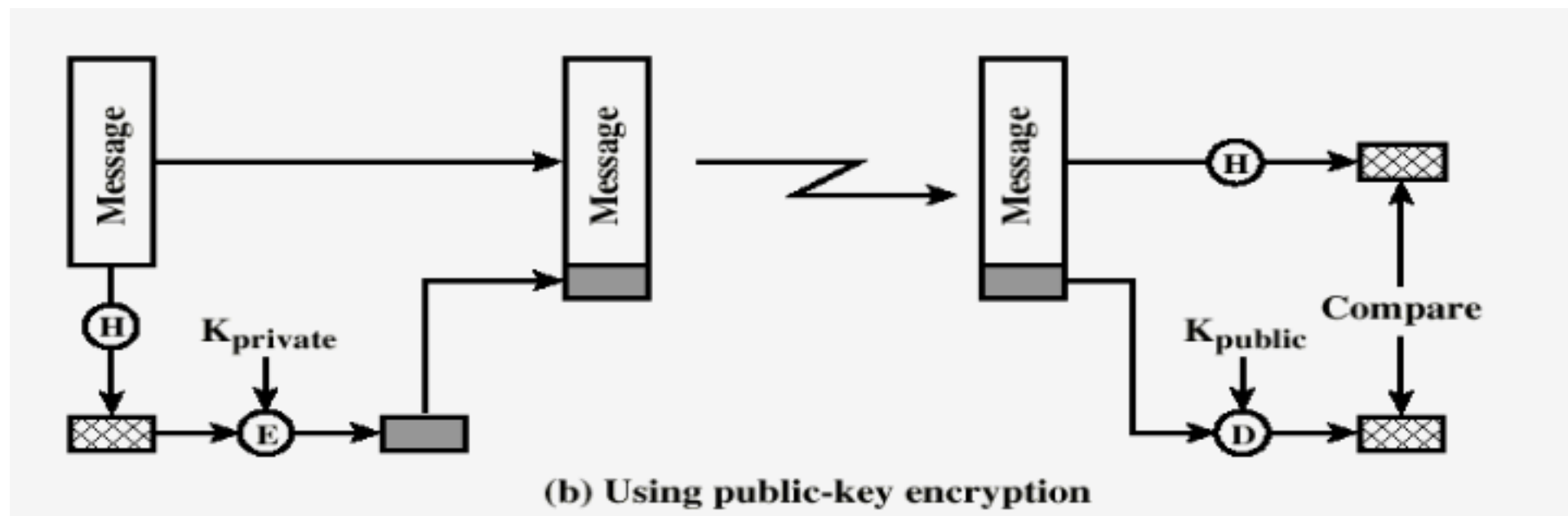
X.509 Certificates

- issued by a Certification Authority (CA), containing:
 - version (1, 2, or 3)
 - serial number (unique within CA) identifying certificate
 - signature algorithm identifier
 - issuer X.500 name (CA)
 - period of validity (from - to dates)
 - subject X.500 name (name of owner)
 - subject public-key info (algorithm, parameters, key)
 - issuer unique identifier (v2+)
 - subject unique identifier (v2+)
 - extension fields (v3)
 - signature (of hash of all fields in certificate)
- notation $CA\langle A \rangle$ denotes certificate for A signed by CA

X.509 Formats



Typical Digital Signature Approach



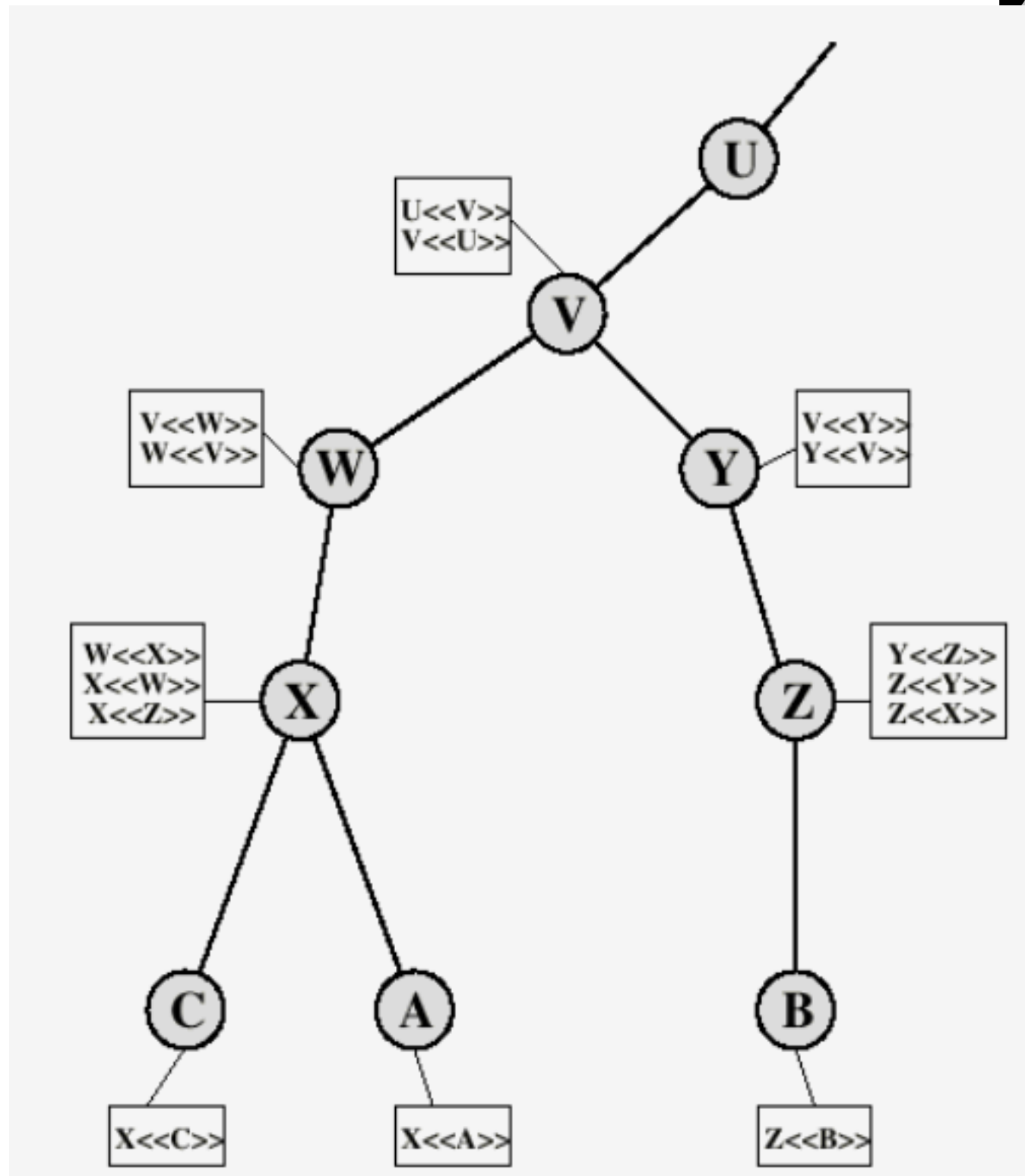
Obtaining a User's Certificate

- Characteristics of certificates generated by CA:
 - Any user with access to the public key of the CA can recover the user public key that was certified.
 - No part other than the CA can modify the certificate without this being detected.

CA Hierarchy

- if both users share a common CA then they are assumed to know its public key
- otherwise CA's must form a hierarchy
- use certificates linking members of hierarchy to validate other CA's
 - each CA has certificates for clients (forward) and parent (backward)
- each client trusts parents certificates
- enable verification of any certificate from one CA by users of all other CAs in hierarchy

X.509 CA Hierarchy



Revocation of Certificates

- Reasons for revocation:
 - The users secret key is assumed to be compromised.
 - The user is no longer certified by this CA.
 - The CA' s certificate is assumed to be compromised.

Authentication Procedures

- X.509 includes three alternative authentication procedures:
- One-Way Authentication
- Two-Way Authentication
- Three-Way Authentication
- all use public-key signatures

One-Way Authentication

- 1 message (A->B) used to establish
 - the identity of A and that message is from A
 - message was intended for B
 - integrity & originality of message
- message must include timestamp, nonce, B's identity and is signed by A

Two-Way Authentication

- 2 messages (A->B, B->A) which also establishes in addition:
 - the identity of B and that reply is from B
 - that reply is intended for A
 - integrity & originality of reply
- reply includes original nonce from A, also timestamp and nonce from B

Three-Way Authentication

- 3 messages (A->B, B->A, A->B) which enables above authentication without synchronized clocks
- has reply from A back to B containing signed copy of nonce from B
- means that timestamps need not be checked or relied upon

X.509 Version 3

- has been recognised that additional information is needed in a certificate
 - email/URL, policy details, usage constraints
- rather than explicitly naming new fields defined a general extension method
- extensions consist of:
 - extension identifier
 - criticality indicator
 - extension value

Certificate Extensions

- key and policy information
 - convey info about subject & issuer keys, plus indicators of certificate policy
- certificate subject and issuer attributes
 - support alternative names, in alternative formats for certificate subject and/or issuer
- certificate path constraints
 - allow constraints on use of certificates by other CA' s

Authentication Procedures

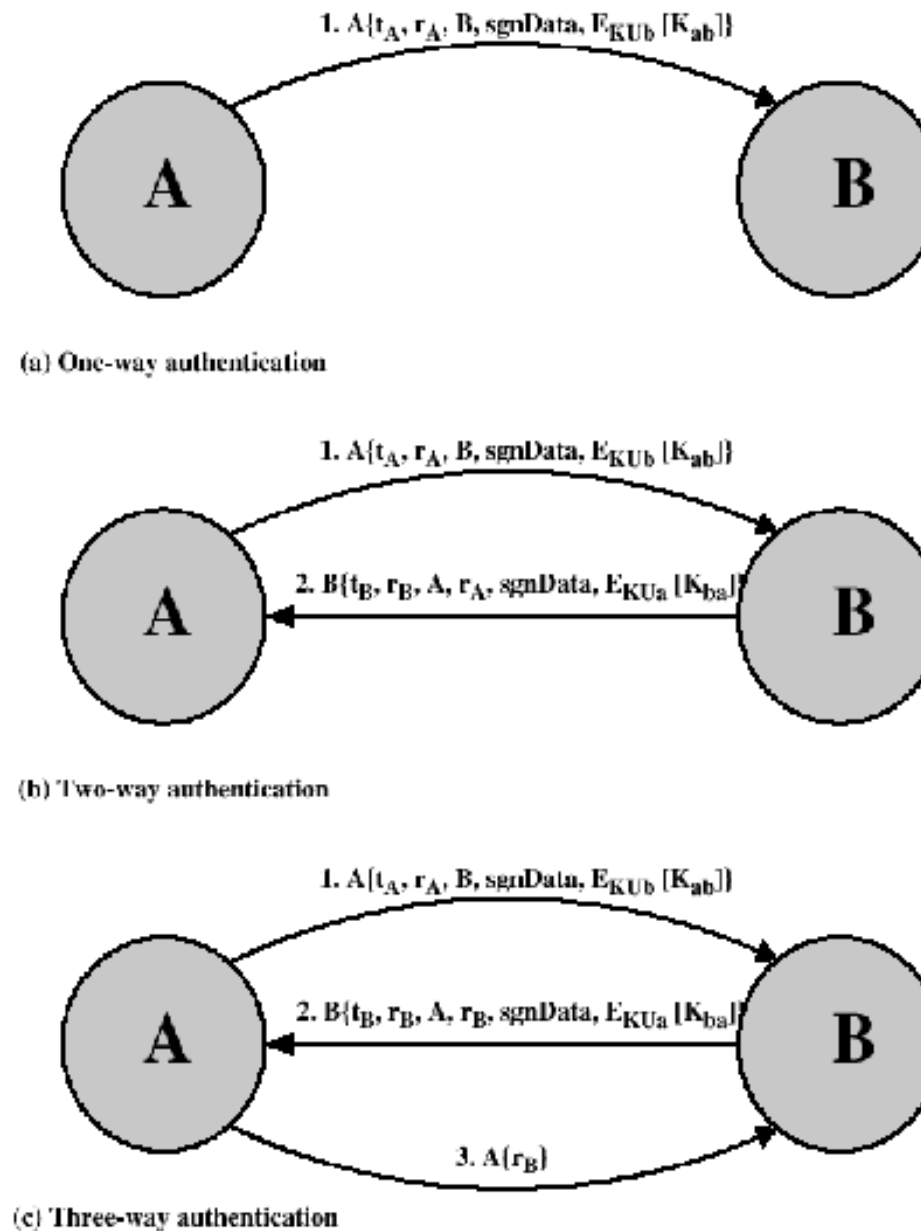


Figure 4.5 X.509 Strong Authentication Procedures